

White Paper - A Framework for Information Security and Infrastructure Resilience in Distributed Educational Environments

Author: Arttu Karppanen,

Information Security Management Lead

Date of original plan: Q1 2025

Subject: ISO 27001-Aligned Risk Treatment and Infrastructure Optimization for Multi-Campus Institutions

0. Forensic Drivers

This framework was not developed in a vacuum. It was designed as a direct response to documented system failures, specifically [IR-2025-1021](#) and [IR-2026-0108](#). These incidents highlighted critical vulnerabilities in the institution's **Access Control**, **Information Integrity**, and **Employment Lifecycle**. The following sections outline the systemic remediations required to prevent the recurrence of such breaches.

1. Executive Summary

This paper outlines a standardized **Information Security Management System (ISMS)** framework specifically designed for educational institutions operating across multiple campuses with constrained budgets. The model addresses the common "unmanaged" state of school IT, characterized by shared administrative access, lack of network segmentation, and high vulnerability to ransomware—and replaces it with a structured, risk-based architecture aligned with **ISO/IEC 27001:2022**.

2. The Case for Foundational Security

In many educational digital transformations, a common pitfall is prioritizing user-facing professional development (PD) over infrastructure integrity. However, a security-first approach recognizes that technical resilience is the prerequisite for all digital learning. Without a secure foundation, institutional availability is compromised, and the risk of data exfiltration remains unacceptably high.

3. Phase 1: Immediate Risk Treatment (The Baseline Model)

The framework initiates by addressing critical non-conformities through high-impact, low-cost technical controls.

3.1 Identity and Access Management (Annex A 5.15 - 5.18)

The model specifies the removal of administrative rights from all standard user endpoints. Operating under the **Principle of Least Privilege (PoLP)**, the framework limits the execution environment of students and staff, effectively mitigating 90% of critical OS vulnerabilities.

- **Case Justification:** This control directly remediates the root cause of unauthorized system-wide modifications and mass deletions observed in [IR-2025-1021](#).
- **Enforcement:** Mandatory unique credentials for all administrative interfaces.
- **Physical Control:** Standardized "Inactivity Timeouts" to prevent unauthorized access to unattended terminals.

3.2 Endpoint Hardening and Vulnerability Management (Annex A 8.7 - 8.8)

The strategy utilizes existing native tools (e.g., Microsoft Defender) to establish a baseline of malware protection without incurring licensing overhead.

- **Remediation:** Implementation of a formalized, automated patching cycle to address legacy software vulnerabilities, which are identified as the primary root cause for data encryption incidents (Ransomware).
-

4. Phase 2: Centralized Operational Control

As the ISMS matures, the framework transitions from local management to centralized, automated oversight, ensuring a "Force Multiplier" effect for lean IT teams.

4.1 Remote Monitoring and Management (Annex A 8.16)

The architectural design requires the deployment of a centralized **Remote Monitoring and Management (RMM)** agent (e.g., Tactical RMM or similar FOSS solutions). This enables:

- Real-time health telemetry across all distributed campuses.
- Centralized software deployment and audit logging to provide forensic visibility during incidents.
- The ability to detect and halt anomalous behavior in real-time.

4.2 Network Segregation and Perimeter Defense (Annex A 8.22)

The framework replaces flat network topologies with a **VLAN-segmented architecture**.

- **Isolation:** Logical separation of Student, Staff, and Administrative networks.
- **Perimeter Hardening:** Implementation of Open-Source Unified Threat Management (UTM) firewalls (e.g., pfSense/OPNsense) to provide Intrusion Prevention Systems (IPS) and secure site-to-site VPN tunnels.

4.3 Mobile Device Management (MDM) (Annex A 8.1)

To secure portable assets, the model integrates a Mobile Device Management solution (e.g., Headwind MDM). This ensures that educational tablets are locked to specific application profiles (Kiosk Mode) and remain subject to remote-wipe protocols in the event of theft or loss.

5. Phase 3: Governance and Business Continuity

The final phase of the framework focuses on institutionalizing security through formal policy and resilience testing.

5.1 Business Continuity and Information Security Continuity (Annex A 5.29)

The model mandates a **3-2-1 Backup Strategy** to ensure data availability. By utilizing a hybrid of cloud and on-premises storage, the institution ensures that "Recovery Time Objectives" (RTO) are met even in the event of a total site failure or a large-scale data exfiltration event.

5.2 Policy and Procedure Development (Clause 5.2)

Strategic resilience is achieved through the formalization of:

- **Employment Lifecycle Policy:** A critical requirement to address the post-employment exfiltration risks illustrated in [IR-2026-0108](#). The framework mandates automated account revocation upon termination.
 - **Acceptable Use Policies (AUP):** Defining user expectations regarding institutional data.
 - **Incident Response Plans (IRP):** Outlining a structured response to security breaches based on forensic observations.
 - **Information Security Awareness:** Continuous education for "Interested Parties" to mitigate the risk of social engineering.
-

6. Conclusion: The Strategic Value of the Model

This framework demonstrates that enterprise-grade security is attainable for cost-averse institutions. By prioritizing the "**Security Foundation**" over surface-level digital initiatives, an institution protects its most valuable assets: its reputation, its operational continuity, and its students' data.

This model serves as a scalable blueprint for any organization seeking to align with global security standards (ISO 27001) while maintaining a lean operational budget through the

strategic use of open-source innovation. By remediating the systemic failures noted in [IR-2025-1021](#) and [IR-2026-0108](#), the institution moves from a reactive posture to a resilient, managed state.